

OFFSEC

EXPLORAÇÃO



6

LISTA DE FIGURAS

Figura 1 - Brute Force	12
Figura 2 – Wireshark	16
Figura 3 - <i>Eavesdropping</i>	17
Figura 4 – Arpspoofing	18
Figura 5 - <i>TCP Hijacking</i>	20
Figura 6 - <i>Session Hijacking</i>	21
Figura 7 – MITM	21
Figura 8 - VLAN hopping	23
Figura 9 – Envenenamento DNS.....	23
Figura 10 – DOS	24
Figura 11 - SNMP	27
Figura 12 - SMTP	29
Figura 13 – FTP	29
Figura 14 - Metasploit.....	31
Figura 15 - Console	32
Figura 16 – Search.....	34
Figura 17 – Sessions.....	34

SUMÁRIO

EXPLORAÇÃO.....	4
1 INTRODUÇÃO	4
1.1 Mapeamento de vulnerabilidades.....	4
2 TÉCNICAS DE ATAQUE.....	5
2.1 Táticas de decepção	9
2.2 Conclusão de tarefas por meio da engenharia social.....	10
3 ATAQUES EM REDES.....	14
4 EXPLOITS.....	25
5 O QUE É METASPLOIT	30
5.1 Metasploit.....	30
REFERÊNCIAS.....	35

EXPLORAÇÃO

1 INTRODUÇÃO

Aproveite as informações para se preparar para a exploração. Agora que você tem um entendimento mais profundo das vulnerabilidades do destino, pode iniciar o processo de transformação dessas informações de vulnerabilidade em explorações acionáveis.

1.1 Mapeamento de vulnerabilidades

O mapeamento de vulnerabilidades é o ato de reconhecer a conexão entre uma vulnerabilidade e seu destino associado. O alvo pode ser uma pessoa, processo, dispositivo, tecnologia, objeto físico (que não seja o computador) etc. Esse mapeamento fornece uma referência para a escolha de técnicas e explorações de ataque.

Um mapa de vulnerabilidade é mais abrangente que os resultados de uma única verificação. É um documento tático que é informado por todas as suas verificações de vulnerabilidade. Também pode conter informações não técnicas, como destinos de phishing e pontos de fraca segurança física. Você o atualiza com vulnerabilidades recém-descobertas e o usa para planejar seus ataques. O mapa de vulnerabilidades pode ser um documento separado ou parte de seu documento de planejamento tático maior.

Ao realizar pentest, você deseja dar prioridade a atividades com maior probabilidade de atingir os requisitos do cliente e suas atividades diárias podem ter prioridades variáveis, à medida que as investigações geram leads promissores ou atingem becos sem saída. Além disso, a maioria dos pentesters tem tempo limitado, portanto, você pode ter que mudar as prioridades com base no cronograma e na disponibilidade de metas ou de seus próprios recursos. Ao priorizar as atividades, siga estas práticas recomendadas:

- Projeto, gerencie os recursos da equipe de pentest para atingir os requisitos do cliente dentro dos limites de tempo. Dê prioridade antecipada às atividades que precisam de tempo extra ou dependem de oportunidades, como verificações lentas ou engenharia social.
- Dê prioridade às atividades com maior probabilidade de revelar novos alvos e vetores de ataque.
- Considere maximizar estrategicamente o momento das "vitórias rápidas" e comprometer as "frutas fracas" para fins políticos, como se o cliente precisasse obter sucesso durante as instruções de status.

2 TÉCNICAS DE ATAQUE

Os ataques específicos escolhidos por uma equipe de pentest dependerão do ambiente de destino. No entanto, existem ataques comuns com os quais todo diretor de segurança da informação (CISO) deve se preocupar. Isso inclui:

- Engenharia social, incluindo distribuição de phishing e malware.
- Ataques de injeção, incluindo injeção de SQL, XSS (cross-site scripting), falsificação de solicitação entre sites (XSRF) e passagem de diretório.
- Negação de serviço (DoS).
- Sequestro de sessão/ataques do tipo man-in-the-middle.
- Reutilização de credenciais.
- Forçamento bruto/quebra de senha.

Muitos tipos de ataques usam técnicas comuns, como falsificação/representação, reprodução de tráfego autorizado de maneira não autorizada ou exploração de vulnerabilidades de software.

Hoje, os ataques mais bem-sucedidos envolvem algum nível de engenharia social, clicando em sites confiáveis que foram comprometidos ou enviando códigos ou links maliciosos por e-mail ou mídia social. As redes privadas tendem a ter menos controles de segurança do que a Internet, mas são mais difíceis de acessar para quem

está de fora. Você teria que encontrar uma maneira comum de obter acesso a uma rede privada, como por exemplo:

- Instalação de malwares de engenharia social em um computador interno.
- Invadir um servidor WAP ou acesso remoto.
- Plantando fisicamente um dispositivo malicioso na rede privada.
- Conluio com informações privilegiadas.

Explorações e payloads, explorações e cargas úteis trabalham juntas para comprometer um sistema, mas não são a mesma coisa. A exploração é o mecanismo que entrega a carga útil. É uma sequência de comandos que tira proveito de uma vulnerabilidade. Os tipos típicos de exploração incluem:

- Estouros de buffer.
- Injeção de código.
- Explorações de aplicativos da web.

Algumas ferramentas classificam suas explorações com base na confiabilidade e eficácia. Por exemplo, o Metasploit possui um sistema de classificação que varia de manual (instável, difícil de usar, basicamente uma negação de serviço) a baixo (baixa taxa de sucesso de 50%), até excelente (sucesso quase sempre sem interromper o serviço de destino). Nem todas as explorações precisam ser de natureza técnica. Por exemplo, você pode usar a engenharia social como sua exploração, induzindo sua vítima a instalar malware no dispositivo.

Depois de invadir um sistema usando uma exploração, você poderá entregar a carga útil. Esse é o código que será executado no destino, executando algum tipo de tarefa ou fornecendo controle interativo ao invasor. Exemplos de cargas comuns incluem:

- Meterpreter.
- VNC ou outro controle remoto.
- Backdoors e cavalos de Troia.
- DLLs mal-intencionadas.
- Worms e vírus com propagação.

Payloads (ou cargas úteis) podem executar tarefas por conta própria sem nenhuma direção adicional ou podem aguardar comandos do invasor. Eles podem abrir uma porta de atendimento e aguardar a conexão de um invasor ou podem fazer uma conexão de volta ao invasor. Isso é especialmente útil quando a vítima está atrás de um firewall que o invasor não consegue ultrapassar.

A maioria das explorações e cargas úteis são específicas da plataforma. No entanto, geralmente você pode escolher qual carga útil deseja que a exploração entregue. Em alguns casos, a exploração fornecerá uma pequena carga útil chamada stager. Leve e confiável, o stager é uma espécie de grupo avançado usado para ganhar posição na vítima.

Depois que o stager é iniciado, ele baixa a carga útil maior (estágio) do invasor. Algumas cargas são independentes e não requerem o processo de estágio de duas etapas. No Metasploit, essas cargas independentes são chamadas de individuais.

Cross-compiled code é um código que foi compilado em um executável em uma plataforma, mas foi projetado para ser executado em uma plataforma diferente. Essa é uma abordagem muito comum ao criar suas próprias explorações.

Por exemplo, você pode usar o Metasploit Pro ou o msfvenom no Kali Linux para criar um pacote malicioso que você enviará para um destino do Windows ou Android. Se você projetou a carga útil da exploração para se conectar novamente a você quando iniciada, poderá iniciar um ouvinte que aguardará a conexão de entrada. Ser capaz de usar a mesma ferramenta para atacar vários tipos de alvo é muito conveniente, economiza tempo e recursos para o pentest.

A modificação de exploração é o processo de alterar uma exploração que funciona contra uma vulnerabilidade específica, porém, não funciona sob certas condições. Um exemplo comum disso seria um estouro de buffer que funciona contra um serviço específico do Windows, entretanto, não funciona se algum service pack tiver sido aplicado.

Os service packs incluem patches para a exploração original. No entanto, o autor do service pack pode ter criado apenas uma variante da vulnerabilidade original. O pentest pode tentar localizar a alteração exata e modificar a exploração para explicar a diferença.

Normalmente, um depurador é usado para ver como o destino responde a diferentes comandos.

As ferramentas comuns usadas na modificação de exploração incluem:

- Metasploit.
- Depurador de imunidade.
- Android Debug Bridge (ADB).
- Java Debugger (jdb).
- Mona.py.

Exploit Chaining é o ato de usar várias explorações para formar um ataque maior. O sucesso do ataque depende de todas as explorações que fazem sua parte. Sua natureza distribuída, usando múltiplas formas de ataque, as torna complexas e difíceis de se defender.

Algumas explorações encadeadas devem ser executadas consecutivamente, sendo que cada uma depende da primeira para ser concluída. Contudo, isso não é um requisito. Você poderia ter exploits encadeados executando em paralelo. Cada parte teria que estar completa e no lugar para que o ataque final ou a carga útil fosse bem-sucedida.

- Uma exploração Metasploit que resulta em um shell no nível do usuário, seguido de um ataque de escalação de privilégios local para fornecer privilégios no nível do sistema do shell.
- Um módulo que executa injeção SQL, desvio de autenticação, upload de arquivo, injeção de comando e escalação de privilégios para finalmente fornecer ao invasor um shell no nível raiz.
- Invadir fisicamente (ou eletronicamente) uma rede privada, plantar um dispositivo mal-intencionado e usá-lo para descobrir e atacar sistemas vulneráveis.
- Distrair um guarda de segurança para que um colega possa adulterar uma câmera ou um sistema de alarme, enquanto outro colega invade um escritório particular para roubar documentos importantes.

Prova de conceito de desenvolvimento ou (PoC) é uma exploração benigna desenvolvida para destacar vulnerabilidades. Geralmente é criada por um pesquisador de segurança e, depois, demonstrada à organização de destino ou ao público em geral.

Embora os aspectos técnicos da vulnerabilidade possam ser publicados detalhadamente, muitos pesquisadores não incluem as especificidades de como seu PoC funciona para desencorajar os agentes mal-intencionados de usar esse conhecimento para criar uma exploração real.

2.1 Táticas de decepção

A decepção é o principal mecanismo de engenharia social. É usado para criar confiança, simpatia, medo, ganância ou urgência – qualquer coisa para induzir a vítima a revelar informações ou a fazer algo que não deveria. A seguir, são apresentadas algumas técnicas comuns de enganação usadas em engenharia social.

Posando como alguém/algo que você não é:

- Um colega de trabalho sitiado que precisa que você procure algumas informações para ele.
- Uma figura de autoridade de uma agência governamental ou policial que ameaça prendê-lo ou penalizá-lo com multas severas.
- Um novo funcionário, especialmente em uma posição de diretoria, precisando de sua ajuda.
- Alguém do departamento de TI que deseja que você insira novamente suas credenciais em um banco de dados recentemente reconstruído.
- Um fornecedor ou fabricante de sistemas avisando sobre uma vulnerabilidade de segurança crítica e oferecendo o envio de um *patch*.
- Um cliente tentando redefinir sua senha do portal de login.
- Um colega de trabalho ou associado de negócios que usa linguagem privilegiada para ganhar confiança, enquanto solicita que você execute alguma tarefa para eles.

- Um amigo ou parente que está com problemas e precisa de sua ajuda.
- Um fornecedor ou credor insistindo para que você efetue um pagamento em atraso. Oferecer algo que a vítima realmente não precisa:
- Distribuir malware disfarçado de música, software, jogos ou vídeos engraçados gratuitos.
- Oferecer ajuda se ocorrer um problema e, em seguida, fazer com que o problema ocorra para que a vítima chame sua ajuda.
- Enviar janelas pop-up ou mensagens falsas solicitando que o usuário forneça credenciais.
- Enviar um e-mail com um anexo infectado.
- Publicar um link para um site malicioso nas mídias sociais.

Deixando um pendrive, cartão de memória ou DVD espalhados pelo local de trabalho com software malicioso.

2.2 Conclusão de tarefas por meio da engenharia social

Muitas vezes, um invasor não tem acesso direto a um sistema que deseja comprometer. Eles devem depender de um usuário inconsciente para ajudá-lo. Além de abrir anexos de e-mail maliciosos ou fornecendo informações no telefone, o usuário pode ser persuadido a executar alguma outra tarefa que não deveria. Isso geralmente requer mais esforço e habilidade da parte do atacante. Os exemplos incluem:

- Desativar ou ignorar os controles de segurança.
- Conceder acesso físico ou de rede.
- Criar ou redefinir credenciais que o invasor pode usar.
- Entrega ou encaminhamento de mensagens, fax, documentos ou e-mails.
- Instalando software.
- Autorizar pagamentos.
- Conectando ou desconectando dispositivos.

- Reconfigurando um sistema.

Ataques de dicionário é o tipo mais direto de ataque automático de senha. Uma ferramenta de quebra de senha percorre uma lista de palavras até encontrar a senha ou esgotar a lista. A esperança é que a lista seja grande o suficiente para conter a senha.

Como a maioria dos usuários escolhe senhas simples e fáceis de lembrar, são grandes as chances de encontrar muitas senhas comuns na lista. Pesquisadores de segurança passaram anos coletando e agrupando listas de palavras. Alguns sites on-line, sob o pretexto de testar a força das senhas, na verdade coletam senhas dos visitantes para adicionar a essas listas.

Existem limites práticos para usar um ataque de dicionário. Você deve primeiro saber o nome do usuário. Alguns crackers de senha incluem listas de nomes de usuário comuns, incluindo contas do tipo administrador. As listas de senhas podem se tornar pesadas. Uma lista de 1,5 bilhão de palavras tem cerca de 15 GB (descompactado). Pode ser difícil para o cracker de senha (ou seu sistema) carregar ou gerenciar. A maioria dos sistemas possui políticas que bloqueiam um usuário após apenas algumas tentativas erradas de senha. Existem várias técnicas que você pode usar para contornar os limites. Isso inclui:

- Roubar uma cópia do arquivo ou banco de dados que contém as credenciais do usuário e tentar decifrar as senhas off-line.
- Induzir o sistema a "despejar" suas senhas (no formato hash) para que você possa decifrá-las off-line.
- Interceptar uma autenticação de rede e enviar o hash de login interceptado para o cracker de senha.
- Executar o cracker de senhas em um serviço de rede que não possui uma política de bloqueio.
- Executar o cracker de senhas em uma conta de usuário, como administrador ou raiz, isenta de uma política de bloqueio.

Um rainbow table attack é um tipo de ataque de dicionário no qual as senhas na lista de palavras foram pré-computadas em seus valores de hash correspondentes e, depois, compactadas de maneira altamente eficiente. Isso torna os ataques de quebra de senha off-line mais rápidos. O cracker não precisa gastar tempo calculando o hash de todas as senhas que tenta.

A maioria dos sistemas operacionais não armazena credenciais do usuário em texto não criptografado. Em vez disso, eles armazenam hashes das senhas. Quando um usuário faz login, o sistema pega a senha enviada e a faz hash. Em seguida, ele compara o resultado ao hash em seu arquivo de credenciais. Se houver uma correspondência, presume-se que o usuário tenha fornecido a senha correta e é permitida a entrada.

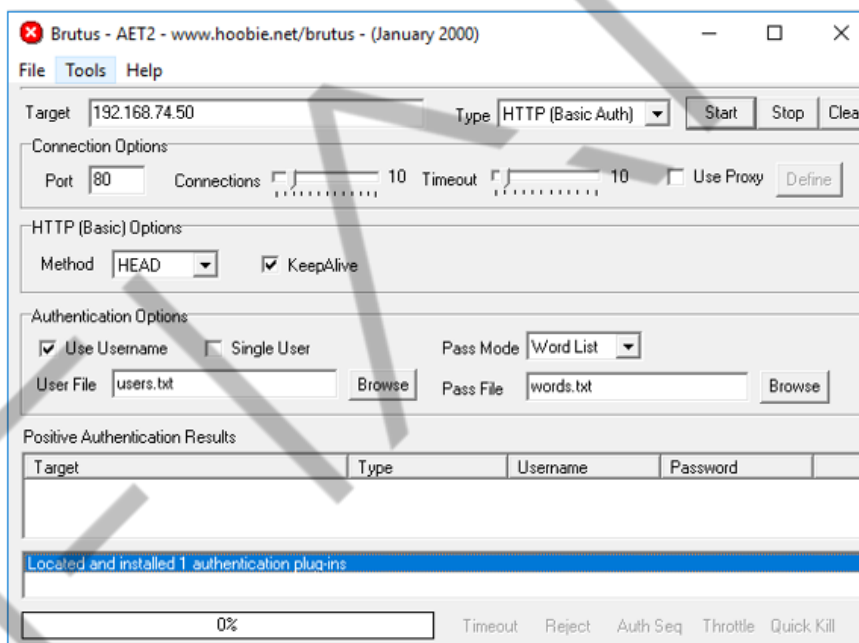


Figura 1 - Brute Force
Fonte: Elaborado pelo autor (2019)

Se você conseguir roubar o arquivo de credenciais que contém as senhas com hash dos usuários, poderá realizar um ataque off-line nesse arquivo. Se o seu dicionário contiver hashes pré-computados em vez de senhas em texto sem formatação, o cracker de senhas poderá simplesmente comparar os hashes de senha com os hashes do dicionário até encontrar uma correspondência.

O crack seria excepcionalmente rápido. A desvantagem, no entanto, é que a maioria dos hashes é consideravelmente maior que a senha original. O tamanho do seu dicionário pode se tornar pesado.

Uma rainbow table attack é um compromisso entre uma tabela de texto sem formatação e uma tabela de hash pura. Ele usa uma função de redução especial para reduzir drasticamente o tamanho do dicionário. Por exemplo, 2,5 milhões de hashes podem ser armazenados em um arquivo de texto com 25 entradas. Para comparação, uma rainbow table com 64 GB de tamanho pode calcular mais de 70 trilhões de hashes.

Por outro lado, um dicionário de texto sem formatação do mesmo tamanho conteria cerca de 6,5 bilhões de senhas. Uma tabela de hash pura conteria apenas cerca de 4 bilhões de hashes. A desvantagem de uma rainbow table é que ela requer mais poder computacional do que uma tabela de hash pura. Isso ocorre porque ele precisa executar alguns cálculos a partir de suas "cadeias" de hash para produzir os valores que não são armazenados diretamente. No entanto, é de longe a melhor opção para decifrar senhas complexas e ordens de magnitude mais eficientes do que um dicionário de texto sem formatação.

Os crackers de senha que usam rainbow table incluem:

- Ophcrack.
- RainbowCrack.
- CAPEC.

Um ataque de força bruta de credencial é aquele em que o invasor tenta muitas senhas na esperança de, eventualmente, adivinhar a correta. Se o dicionário da lista de palavras do invasor estiver esgotado, a ferramenta de cracking poderá tentar variações das senhas substituindo números ou caracteres especiais por letras.

Também pode simplesmente tentar combinações de caracteres até que a senha seja encontrada. Se a senha for usada para criar uma chave de criptografia, o invasor poderá tentar adivinhar a chave. Um exemplo disso é uma senha de wi-fi usada para criar uma chave numérica baseada em hexadecimal.

O usuário não precisa adivinhar a senha original, mas usar outras maneiras de extrair a chave e usá-la para acessar o sistema. Se a senha for curta, como um PIN de 4 dígitos, uma ferramenta automatizada poderá passar por todas as combinações possíveis em minutos. Quanto mais longa e complexa for a senha, mais difícil será a quebra. Se não for prático tentar decifrar a senha, o invasor pode roubar o hash da senha e fornecê-lo no lugar da própria senha.

3 ATAQUES EM REDES

Todas as vulnerabilidades baseadas em rede têm uma coisa em comum: elas permitem que alguém quebre as regras do comportamento normal da rede. Um protocolo é manipulado para que um pacote aparentemente normal tenha valores inesperados ou um servidor recebe uma solicitação inesperada de um cliente mal-intencionado.

As vulnerabilidades baseadas em rede surgiram em primeiro lugar porque pesquisadores e desenvolvedores estavam focados na funcionalidade, não na segurança. A implementação ampla de serviços e protocolos comuns faz de qualquer atualização de segurança um processo demorado e de vários estágios. Enquanto isso, os invasores continuam a explorar as vulnerabilidades existentes e a descobrir novas.

Sniffing é uma maneira simples de obter passivamente muitas informações sobre a rede. Você pode usá-lo para identificar hosts, serviços, tipos de dispositivos, protocolos, sub-redes, endereços IP e muito mais.

O sniffing aproveita particularmente os protocolos de texto não criptografado, como TCP, UDP, IP, ARP, ICMP, IGMP, LDAP, SNMP, SMB, FTP, DNS, DHCP, SMTP / POP3 / IMAP, telnet, HTTP, TFTP, versões não seguras do SIP, protocolos de roteamento não criptografados e muitos outros. Se o tráfego estiver em texto não criptografado, você poderá extrair credenciais, capturar arquivos e imagens, ler mensagens e obter dados destinados a outros usuários e máquinas.

Sniffers como o Wireshark têm a capacidade de recriar sessões TCP inteiras e capturar documentos e imagens inteiros da rede. Mesmo se a carga útil do tráfego estiver criptografada, você ainda poderá extrapolar endereços e portas de origem e

destino, SSIDs da WLAN e vetores de inicialização (dados da chave de criptografia) e mensagens de texto não criptografadas.

Se o tráfego estiver encapsulado dentro de uma VPN, você ainda poderá ver os handshakes da VPN e os endereços IP do invólucro externo. Alguns pacotes, como mensagens ARP, têm estrutura distinta e são facilmente reconhecidos, mesmo quando criptografados. Eles ainda podem ser capturados e reproduzidos em ataques de texto cifrado escolhidos, como o cracking WEP.

O sniffing bem-sucedido exige que duas condições sejam verdadeiras:

- A interface do sniffer deve estar no modo promíscuo. Isso significa que ele captará todo o tráfego, independentemente do MAC de destino. Caso contrário, ele ignoraria o tráfego não endereçado especificamente a ele.
- O tráfego que você deseja detectar deve passar diretamente pela interface do sensor. Em outras palavras, o sniffer deve estar no mesmo segmento de rede compartilhado que o tráfego que ele está “farejando”.
- Se os dispositivos estiverem conectados a um hub, não haverá problema, pois o hub repetirá todos os quadros em todas as portas.
- Se os dispositivos estiverem conectados a um switch, você deve envenenar a tabela MAC do switch para que ele repita o tráfego desejado na porta a qual o sniffer está conectado.
- Se os dispositivos estiverem em uma sub-rede ou VLAN diferente, você deverá instalar um sniffer nesse segmento e envenenar a tabela MAC do switch para repetir os quadros na porta apropriada.
- Se o segmento for sem fio, o sniffer deve estar dentro do alcance do rádio.

Se todo o tráfego desejado passar por um roteador, você poderá comprometer o roteador a encaminhar cópias desse tráfego para o invasor. O uso de um simples túnel GRE (*Generic Routing Encapsulation*) permitirá que roteadores com acesso à Internet encaminhem tráfego para qualquer lugar do mundo.

Em geral, **eavesdropping** é definido como o ato de ouvir secretamente a conversa particular de outra pessoa. Você pode estar ao alcance da audição do alto-falante, embora talvez em um local em que eles não possam vê-lo, como atrás de uma porta ou divisória, na esquina ou ouvindo outro ramal telefônico na mesma linha. Você

também pode plantar um bug em algum lugar da sala que transmita o que ouve a um receptor a alguma distância.

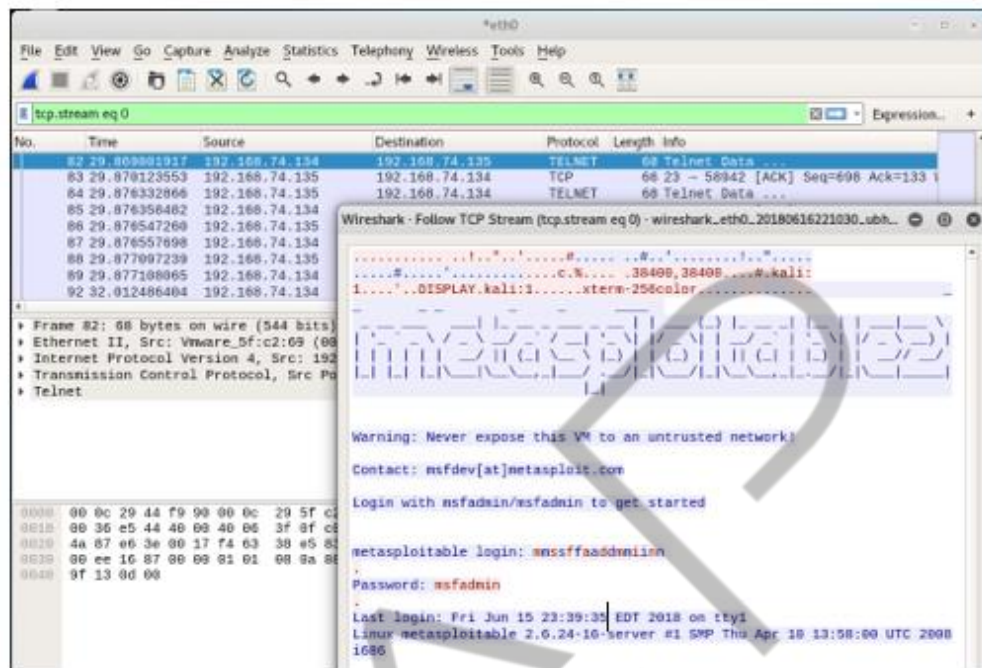


Figura 2 – Wireshark
Fonte: Elaborado pelo autor (2019)

No mundo dos testes de penetração, embora a espionagem possa incluir a audição de alguém ou uma conversa telefônica, também pode se referir a outros tipos de vigilância, incluindo:

- Plantar um sniffer em uma rede.
- Colocar secretamente uma câmera ou microfone na sala.
- Capturar pacotes de VoIP da rede e reproduzindo-os.
- Usar o telefone para gravar alguém digitando uma senha ou PIN na sala.
- Usar um abacaxi wi-fi ou outro dispositivo intermediário para capturar o tráfego sem fio.
- Usar um dispositivo intermediário de captura de IMSI para interceptar chamadas de telefone celular.

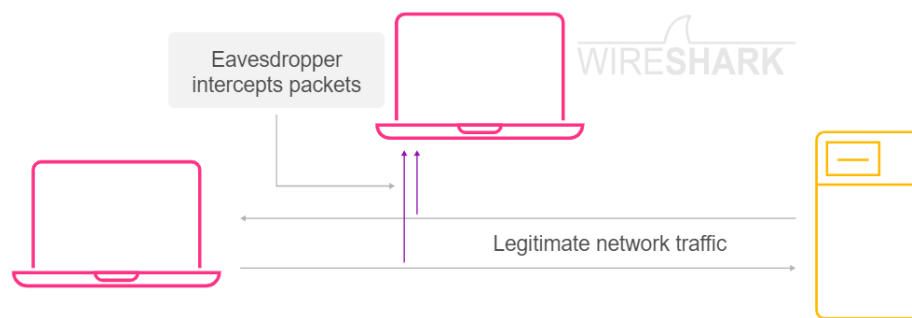
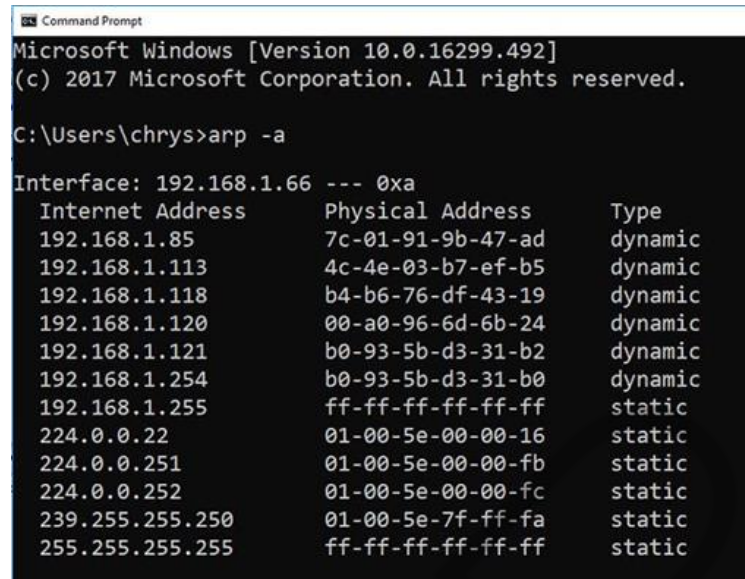


Figura 3 - *Eavesdropping*
Fonte: Elaborado pelo autor (2019)

O envenenamento por ARP ou **ARP poisoning** é o mapeamento deliberado de um endereço MAC incorreto para um endereço IP correto. É usado para redirecionar o tráfego para fins maliciosos e é o mecanismo de falsificação mais comum usado nas redes ethernet e wi-fi. Ele permite que um invasor se insira em um ataque intermediário entre dois *hosts* legítimos.

No TCP/IP, um pacote não pode simplesmente ter um endereço IP de destino antes de ser transmitido em uma rede de acesso múltiplo. Ele também deve ter um endereço OSI camada 2 correspondentes. Nas redes ethernet e wi-fi, esse seria um endereço MAC.

Um host pode usar a resolução de nomes para procurar o endereço IP de um destino, mas também deve usar o ARP para aprender o endereço MAC. Depois que o mapeamento de MAC para IP é determinado, essas informações são armazenadas no cache ARP do host. Como os outros dispositivos podem alterar seu endereço IP, as entradas no cache do ARP expiram e são atualizadas a cada poucos minutos.



```
Microsoft Windows [Version 10.0.16299.492]
(c) 2017 Microsoft Corporation. All rights reserved.

C:\Users\chrys>arp -a

Interface: 192.168.1.66 --- 0xa
Internet Address      Physical Address      Type
192.168.1.85          7c-01-91-9b-47-ad    dynamic
192.168.1.113         4c-4e-03-b7-ef-b5    dynamic
192.168.1.118         b4-b6-76-df-43-19    dynamic
192.168.1.120         00-a0-96-6d-6b-24    dynamic
192.168.1.121         b0-93-5b-d3-31-b2    dynamic
192.168.1.254         b0-93-5b-d3-31-b0    dynamic
192.168.1.255         ff-ff-ff-ff-ff-ff    static
224.0.0.22            01-00-5e-00-00-16    static
224.0.0.251          01-00-5e-00-00-fb    static
224.0.0.252          01-00-5e-00-00-fc    static
239.255.255.250      01-00-5e-7f-ff-fa    static
255.255.255.255      ff-ff-ff-ff-ff-ff    static
```

Figura 4 – Arpspoofing
Fonte: Elaborado pelo autor (2019)

A menos que você codifique os mapeamentos de endereços MAC para IP em sua rede, espera-se que a relação entre um endereço MAC e um endereço IP seja fluida e alterada. Um invasor pode tirar proveito disso de várias maneiras:

- Você pode enviar um fluxo contínuo de respostas ARP falsas, declarando a todo o segmento que o seu MAC é o correto para o endereço IP de destino. Dessa forma, quando os hosts pretendem enviar um pacote para o destino, eles realmente estão enviando para você.
- Você pode enviar um fluxo contínuo de respostas ARP falsas, declarando que seu endereço MAC é o correto para o gateway padrão (roteador). Qualquer host que deseje enviar tráfego para outra rede, incluindo a internet, deve enviá-lo a você.
- Você pode envenenar a tabela MAC de um comutador com respostas ARP falsas, para associar os endereços MAC da vítima à sua porta do comutador. Sempre que o switch receber tráfego destinado à sua vítima, ele não somente encaminhará a porta do switch à qual a vítima está conectada, mas também encaminhará uma cópia da sua porta.

Se você deseja se inserir entre dois hosts em um ataque intermediário, deve envenenar o cache ARP dos dois hosts. Dessa forma, eles se comunicarão por meio de você. Eles não perceberão que você está retransmitindo todas as mensagens enquanto captura uma cópia para si mesmo.

Como você está transmitindo constantemente o endereço MAC falsificado para suas vítimas, elas nunca sentem a necessidade de realizar sua própria transmissão ARP. Eles acham que já possuem o mapeamento. Quando você interrompe o envenenamento por ARP, os dois hosts acabam envelhecendo suas entradas falsificadas dos caches de ARP e aprendem o endereço MAC correto um do outro. Esse processo pode levar até 10 minutos, a menos que você reinicie as máquinas ou limpe manualmente seus caches ARP.

O envenenamento por ARP tem seus limites. Como você está falsificando endereços da camada 2, o envenenador deve estar no mesmo segmento de rede que as vítimas. Se as vítimas estiverem em outra sub-rede ou em uma rede remota, você não poderá conduzir envenenamento por ARP contra elas. Da mesma forma, se você estiver em uma rede que não usa endereços MAC, como ATM, dial-up ou links WAN seriais síncronos, o envenenamento por ARP é inútil.

O **TCP session hijacking** é o ato de ocupar o lugar de um usuário ou cliente depois que ele já estabeleceu uma conexão TCP com um servidor. Normalmente, o usuário ou o dispositivo cliente já foi autenticado e o invasor deseja assumir o controle da conexão sem precisar fornecer credenciais. Esse ataque depende de várias condições para funcionar:

- A sessão deve usar um protocolo de texto não criptografado que possa ser detectado, como telnet, FTP ou rlogin.
- O invasor deve ser capaz de observar e antecipar corretamente o aumento dos números de sequência TCP (eles pulam pseudo-aleatoriamente para evitar o sequestro, mas podem ser previstos após algumas observações).
- Os pacotes não devem ser assinados digitalmente.

As etapas de alto nível para o sequestro de sessão TCP são:

1. Assista ao incremento dos números de sequência TCP do cliente / servidor (pode exigir envenenamento por ARP).
2. Envie ao cliente alguns pacotes TCP FIN falsificados para que ele pense que o servidor deseja encerrar a sessão (alternativamente, conduza e mantenha outro ataque de negação de serviço contra o cliente).
3. Falsifique seu endereço IP e/ou MAC para fingir que você é o cliente.

4. Depois que o cliente for desconectado, continue suavemente a conversa com o servidor.

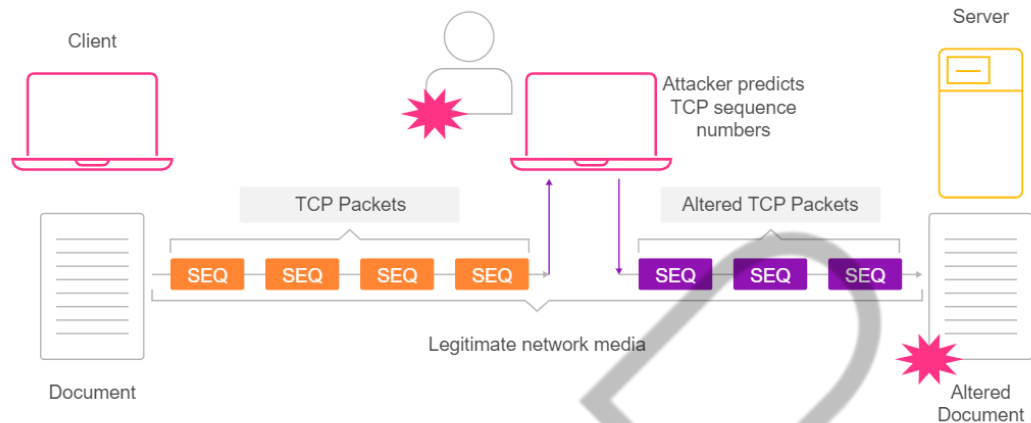


Figura 5 - TCP Hijacking
Fonte: Elaborado pelo autor (2019)

Outra forma de sequestro de **session hijacking** é roubar a credencial da sessão do navegador de um usuário e usá-la para se passar por um usuário em um site.

O HTTP não possui mecanismo no nível do protocolo para rastrear o estado de uma solicitação específica do navegador. Da perspectiva do servidor, todas as solicitações que recebe do cliente são novas. Se a autenticação for necessária, o usuário deverá digitar novamente as credenciais para cada nova solicitação ou algum outro mecanismo deve existir para vincular todas as solicitações em uma única sessão contínua.

O mecanismo mais comum para fazer isso é um cookie, que é um arquivo de texto que o servidor fornece ao navegador do cliente. Ele contém o SID (ID da sessão) dessa sessão da web específica e é usado como um token de autenticação.

O navegador continua apresentando o cookie toda vez que uma solicitação é feita. Dessa forma, o usuário não precisa continuar digitando novamente as credenciais no site. Se você pode roubar o ID da sessão da vítima, você pode colocá-lo em seu próprio cookie e usá-lo.

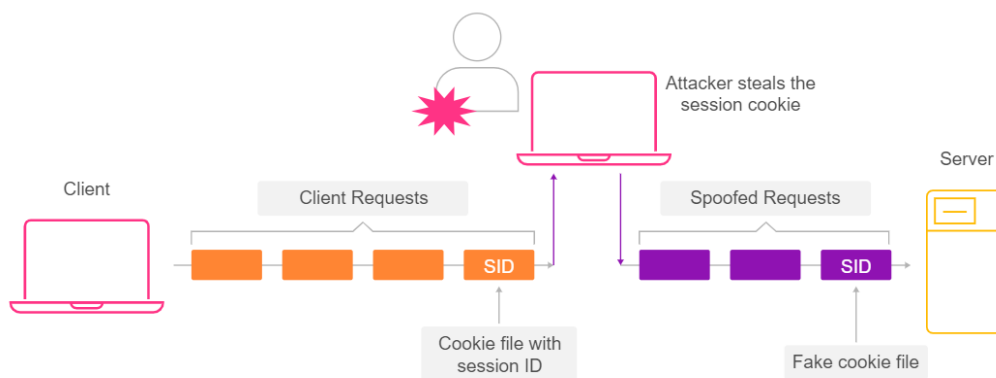


Figura 6 - Session Hijacking
Fonte: Elaborado pelo autor (2019)

Um **ataque do tipo homem no meio (MITM)** é aquele em que o invasor se insere no meio de uma conexão. Difere de um ataque de sequestro, pois não substitui o cliente, mas atua como uma retransmissão entre o cliente e o servidor. Ambos os lados pensam que estão se comunicando diretamente, mas estão realmente fazendo isso por meio do MITM.

O MITM, em seguida, captura as informações que poderiam ser criptografadas ou manipula os dados de alguma outra maneira.

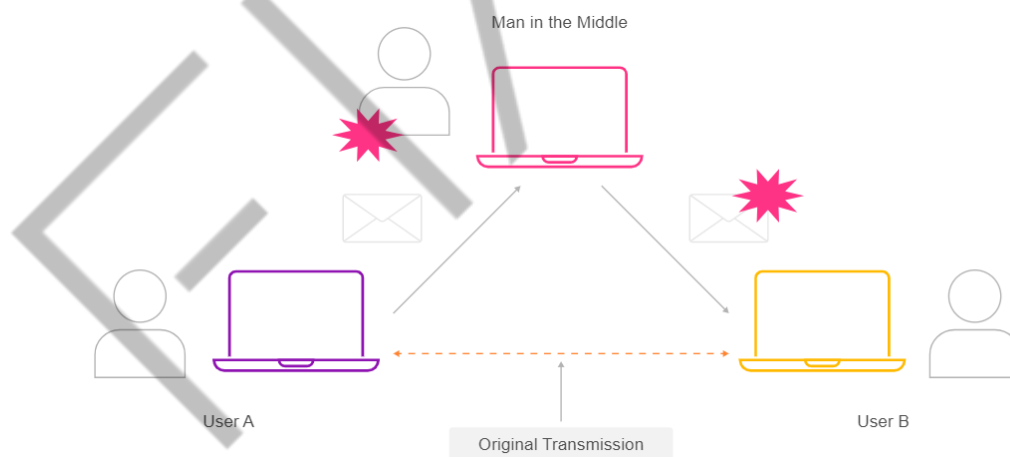


Figura 7 – MITM
Fonte: Elaborado pelo autor (2019)

O MITM requer algum tipo de falsificação, geralmente envenenamento por ARP ou alteração de endereços IP/números de porta. Pode ser frustrado se o cliente e o servidor assinarem digitalmente seus pacotes ou, no caso do site, se o servidor exigir HSTS (HTTP Strict Transport Security).

VLAN hopping é o ato de mover ilegalmente de uma VLAN para outra. Uma VLAN (LAN virtual) é um agrupamento lógico de portas de *switch* que pode se estender por qualquer número de switches em um campus ethernet.

Seu objetivo é organizar os dispositivos por necessidade de segurança e/ou limitar o impacto do tráfego de broadcast na rede maior. Uma rede comutada pode ter (quase) qualquer número de VLANs que se estendem pelo campus, cada uma sendo seu próprio domínio de broadcast com seu próprio ID de sub-rede.

As redes de área metropolitana (MANs) da Metro Ethernet podem até estender as VLANs de uma empresa para outros locais da cidade. Os casos de uso mais comuns são segregar a rede por departamento, tipo de dispositivo ou nível de segurança.

Como as VLANs são logicamente segmentadas para o restante da rede, você normalmente precisa usar um roteador para mover o tráfego entre elas. Isso permite definir listas de controle de acesso e outras políticas para controlar quais hosts podem acessar hosts em outras VLANs.

Normalmente, uma porta do switch ou uma conexão wi-fi pode pertencer apenas a uma VLAN por vez e não pode ser alterada, a menos que seja especificamente configurado pelo administrador da rede. Isso significa que qualquer porta ou SSID ao qual o dispositivo se conectar determina a VLAN em que ele está.

Você precisaria conectar-se a uma porta diferente ou conectar-se a uma WLAN diferente para alterar sua VLAN. Ou, se permitido, um roteador teria que rotear seu tráfego da sua VLAN existente para outras VLANs. No entanto, existem maneiras de contornar essa restrição. Alguns exemplos incluem:

- Transbordar a tabela MAC em um switch vulnerável para que ele se comporte como um hub, repetindo os quadros em todas as portas.
- Configurando a interface de uma máquina atacante para se tornar uma porta de tronco. Em seguida, negociar um não autorizado link de tronco com o switch, o que permite que o tráfego de qualquer VLAN flua por meio desse link. Isso permite que a máquina atacante aplique a desejada tag VLAN aos pacotes maliciosos. O switch entregará esses pacotes à VLAN restrita.

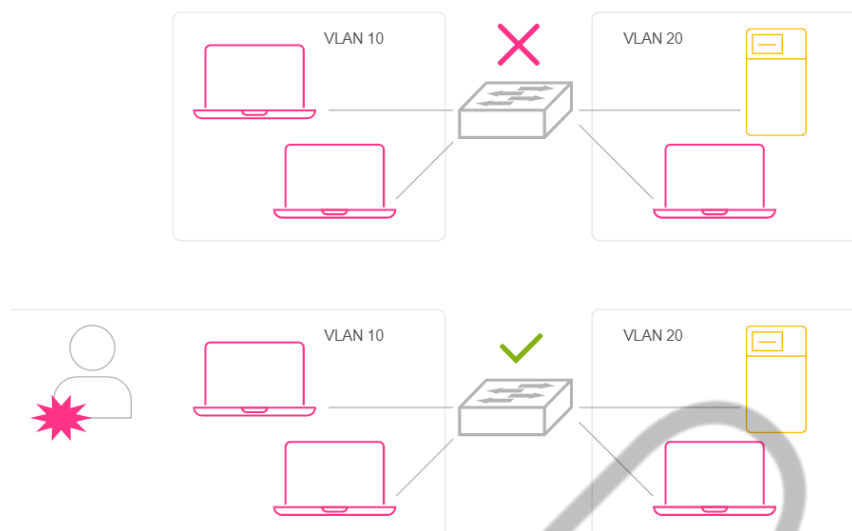


Figura 8 - VLAN hopping
Fonte: Elaborado pelo autor (2019)

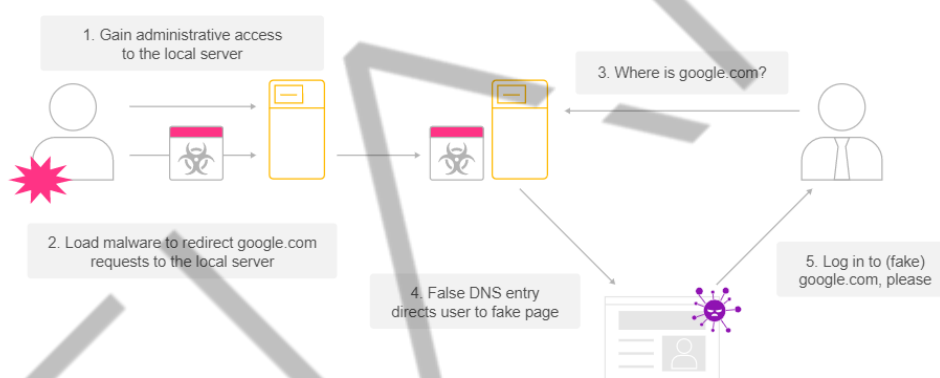


Figura 9 – Envenenamento DNS
Fonte: Elaborado pelo autor (2019)

Alguns governos estrangeiros usam envenenamento de cache DNS contra seus próprios servidores DNS para impedir que seus cidadãos acessem certos tipos de conteúdo na internet. Se você não puder atacar diretamente o servidor DNS, também poderá se disfarçar como servidor DNS local, enviando respostas falsas aos clientes enquanto eles tentam resolver nomes.

Infelizmente, a natureza confiável e aberta do DNS o torna intrinsecamente vulnerável a envenenamentos em cache e ataques de spoof. O Bug Kaminsky (CVE-2008-1447) destacou o desafio de tentar corrigir uma falha fundamental em um protocolo que basicamente roda a internet. O DNSSEC (anexando assinaturas digitais aos registros DNS) foi considerado o único remédio real, mas mesmo 10 anos depois ainda não foi amplamente implementado.

Um **ataque de negação de serviço (DoS)** é aquele que impede o alvo de executar suas tarefas normais na rede. Embora isso normalmente seja realizado inundando o servidor com tráfego de rede, também pode ser realizado travando um serviço ou consumindo todos os recursos do servidor, incluindo CPU, memória, espaço em disco ou conexões de clientes permitidas.

O ataque pode ser específico de protocolo, sistema operacional ou serviço. Você pode tentar criar pacotes para evitar a detecção de IDS ou firewall. Para ataques de DoS baseados no tráfego de rede, é improvável que um único invasor tenha muito (se houver) impacto.

As explorações mais sérias são ataques de negação de serviço distribuído (DDoS), nos quais milhares ou centenas de milhares de máquinas (normalmente em uma botnet) são coordenadas para atacar um único alvo.

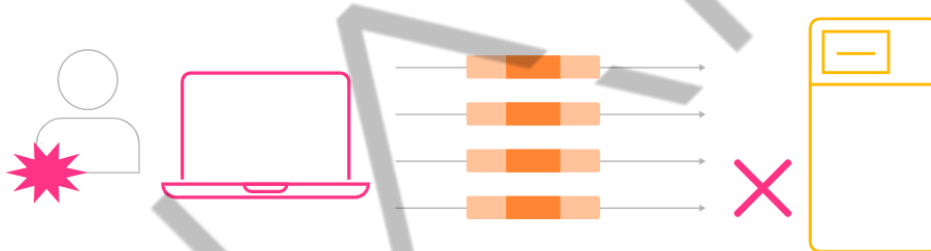


Figura 10 – DOS
Fonte: Elaborado pelo autor (2019)

O teste de estresse é um eufemismo para conduzir um ataque de negação de serviço contra um alvo. Você pode usar scripts, bots ou outras ferramentas para atacar deliberadamente e intensivamente um servidor ou serviço para ver como ele é executado.

Alguns testadores de estresse simplesmente inundam o alvo com o tráfego distribuído de negação de serviço (DDoS). Outros são específicos de aplicativos e simulam números muito altos de solicitações reais do usuário. Um administrador pode usar o teste de estresse para garantir que um site possa suportar ataques ou tráfego anormalmente alto.

Como a intenção é tornar o serviço não funcional, um pentest precisará de autorização para testar uma máquina de produção. Além disso, o cliente precisaria entender as implicações dos servidores ativos de teste de estresse.

Existem muitos serviços e produtos para teste de estresse disponíveis comercialmente on-line. Existem também vários sites on-line que alugam suas *botnet* ilegais para fins de "teste de estresse". Esses sites cobram um preço nominal por hora.

4 EXPLOITS

O Server Message Block (SMB) permite que os clientes leiam e gravem em um serviço de servidor, fornecendo autenticação e comunicação principais para servidores de arquivos e impressão do Windows. Era (e é) tão popular que os sistemas operacionais * nix criaram seu próprio serviço Samba compatível para interoperabilidade Windows / Unix / Linux.

O SMB também possui um dos históricos de vulnerabilidade mais longos de qualquer protocolo de rede em uso atualmente (www.cvedetails.com lista quase 2.700 vulnerabilidades relacionadas a SMB). Apesar de ter sido atualizado várias vezes pela Microsoft, novas vulnerabilidades continuam surgindo. A maioria se aplica à versão do Windows, mas alguns impactam o Samba também.

O Exploit-db.com lista 61 explorações relacionadas ao SMB, que datam de 1995 até o presente. Packetstormsecurity.com lista 314. Metasploit possui 43 em seu banco de dados.

Como o SNMP produz uma riqueza de informações sobre os dispositivos de destino, é uma excelente ferramenta para reconhecimento e enumeração. Um gerenciador de SNMP (também conhecido como sistema de gerenciamento de rede ou NMS) é um aplicativo que é executado continuamente na rede. Em intervalos regulares (geralmente a cada 5 a 15 minutos), ele consulta os dispositivos quanto ao seu status.

Esses dispositivos geralmente são servidores, roteadores, comutadores, pontos de acesso sem fio, hubs e outros dispositivos capazes de executar o serviço SNMP. O serviço SNMP possui um agente que escuta as consultas recebidas do gerente. O gerente deve se identificar com o agente pela sequência de caracteres da comunidade, que é um identificador de texto que deve ser o mesmo no gerenciador e no dispositivo. Se o gerente usar uma string de comunidade diferente, o dispositivo a ignorará.

A cadeia de comunidade padrão para todas as instalações SNMP é pública ou privada, mas pode ser facilmente alterada. A maioria das implementações de SNMP está em texto não criptografado, embora a versão 3 use criptografia.

Normalmente, o NMS faz a consulta, mas um agente pode ser configurado para gerar uma interceptação (um alerta) se algum limite for atingido. As armadilhas podem ser definidas em qualquer número de contadores. Exemplos incluem baixo espaço em disco, alta temperatura da CPU, alta utilização da CPU ou da RAM, interface congestionada e violações de segurança.

Existem três categorias básicas de explorações de SNMP:

- Detectar comunicações SNMP em texto não criptografado entre gerentes e agentes para obter a sequência ou informações da comunidade dos dispositivos. Isso pode incluir estatísticas sobre hardware, tráfego de interface, serviços, usuários, grupos, tabelas de rotas, portas de atendimento, processos em execução e muito mais.
- Se apresentar como um gerente SNMP, fornecendo a sequência correta da comunidade e enumerar informações dos agentes SNMP.
- Explorar a confiança implícita que os gerentes de SNMP têm nos ativos que gerenciam. A maioria dos NMSs não valida com cuidado a entrada de seus agentes. O invasor pode injetar passiva ou ativamente dados XSS ou outras sequências de caracteres formatadas incorretamente do agente no NMS. Isso pode resultar em estouros de buffer ou injeção arbitrária de comandos.

Ferramentas para exploração de SNMP

Algumas ferramentas comuns para explorar SNMP incluem:

- auxiliar / scanner / snmp / snmp_enum
- auxiliar / scanner / snmp / snmp_enumshares
- auxiliar / scanner / snmp / snmp_enumusers

```
msf auxiliary(scanner/snmp/snmp_enum) > run

[+] 192.168.74.50, Connected.

[*] System information:

Host IP           : 192.168.74.50
Hostname          : SERVER00
Description       : Hardware: Intel64 Family 6 Model 5
                   ild 14393 Multiprocessor Free)
Contact           : -
Location          : -
Uptime snmp       : 1 day, 01:15:49.68
Uptime system     : 3 days, 21:19:28.16
System date       : 2018-6-16 18:03:42.7

[*] User accounts:

["moo"]
["Guest"]
["Jason"]
["chrys"]
["hacker"]
["IME_USER"]
["IME_ADMIN"]
["Administrator"]
["DefaultAccount"]

[*] Network information:

IP forwarding enabled : no
Default TTL           : 128
TCP segments received : 144436
```

Figura 11 - SNMP

Fonte: Elaborado pelo autor (2019)

Explorações SMTP: como em quase todos os protocolos comuns da camada 7, o SMTP tem seus compartilhamentos de vulnerabilidades e explorações. Os clientes o usam para enviar e-mail para o serviço de e-mail e os servidores de e-mail (MX) usam para encaminhar mensagens de e-mail um para o outro. A versão original da porta TCP 25 do SMTP foi enviada em texto não criptografado.

Embora a maioria dos clientes use uma versão criptografada no TCP 587 ou 465, a maioria dos e-mails servidor-servidor ainda é enviada em texto não criptografado pela internet, sem autenticação entre os servidores.

Embora muitos produtos SMTP tenham vulnerabilidades de código que permitem ao invasor obter privilégios de root e executar comandos arbitrários por meio de um ataque de estouro, pentesters também procuram enumerar contas de e-mail do servidor, além de retransmitir mensagens de spam e phishing.

O SMTP possui dois comandos em particular que ajudam na enumeração. O VRFY pede ao servidor para verificar rapidamente se existe uma conta de e-mail. O EXPN pede que o servidor expanda uma lista de endereçamento ou para ver quem são os verdadeiros destinatários.

A maioria dos servidores de e-mail permite desativar os dois comandos. As explorações de SMTP e algumas ferramentas populares incluem:

- Banner.
- Captura de detecção de texto não criptografado de autenticação, mensagens de e-mail e anexos: Wireshark, juntamente com um envenenador ARP como Ettercap ou Cain e Abel.
- Retransmissão de spam e phishing: MailBomber, Kali SET, Metasploit Pro Assistente rápido para campanha de phishing, ReelPhish, King Phisher.
- Enumeração de contas de e-mail: telnet, smtp-user-enum do Kali Linux, iSMTP, Metasploit / auxiliar / scanner / smtp / smtp_enum.
- Senhas de contas brutais forçantes: Ncrack, Hydra e Medusa.
- Estouros de buffer para execução arbitrária de código:
- smtp-vuln-cve2010-4344.nse, exploit / windows / e-mail / ms07_017_ani_loadimage_chunksize.
- Escalonamento de privilégios.
- Negação de serviço.
- O desvio de autenticação.

Já existe há muito tempo. É comumente usado para fazer o upload/download eficiente de arquivos de/para um site ou outro local. Se você estiver fazendo um pentest, é muito provável que sua rede de destino tenha um servidor FTP em algum lugar. Nem todos os servidores FTP são vulneráveis. As explorações geralmente são específicas do produto ou da versão.

```
root@kali:/# ismtp -e /root/common.txt -h 192.168.74.50

-----
ismTP v1.6 - SMTP Server Tester, Alton Johnson (alton.jx@gmail.com)
-----

Testing SMTP server [user enumeration]: 192.168.74.50:25
Emails provided for testing: 9

Performing SMTP VRFY test...

Error: String does not match anything..

Performing SMTP RCPT TO test...

[+] moo@gcp.local ----- [ valid ]
[+] chrys@gcp.local ----- [ valid ]
[+] jason@gcp.local ----- [ valid ]
[+] pam@gcp.local ----- [ valid ]
[+] gail@gcp.local ----- [ valid ]
[+] admin@gcp.local ----- [ valid ]
[+] postmaster@gcp.local --- [ valid ]
[-] support@gcp.local ----- [ invalid ]
[-] contact@gcp.local ----- [ invalid ]

Completed SMTP user enumeration test.

-----
Completed in: 0.0s
```

Figura 12 - SMTP

Fonte: Elaborado pelo autor (2019)

Portanto, para determinar se há uma exploração para um serviço FTP, você deve:

1. Usar uma verificação de porta para localizar quaisquer servidores FTP na rede ou host de destino. A maioria dos servidores FTP escuta na porta TCP 21.
2. Fazer a captura de faixa ou impressão digital do serviço FTP para determinar o número exato do produto e da versão.
3. Procurar vulnerabilidades ou exploits para essa versão, ou, eventualmente, escrever seu próprio 0-day exploit.

```
msfadmin@metasploitable:/root$ ftp 192.168.74.135
Connected to 192.168.74.135.
220 (vsFTPd 2.3.4)
```

Figura 13 – FTP

Fonte: Elaborado pelo autor (2019)

Ataques FTP comuns incluem:

- Cleartext sniffing sessões de obtenção de credenciais e cópias de arquivos.

- Buffer overflows em execução de código arbitrário ou dando contas de serviço de acesso shell de root.
- Denial-of-service / ataques consome de fome de recursos todos os espaços em disco de um servidor FTP, capacidade da CPU, RAM, ou permitidas conexões.
- FTP salto-usando um servidor FTP como um homem de meia para abrir uma conexão e enviar comandos para outro servidor.
- Logon FTP anônimo com permissões de forma inadequada de leitura / gravação permitindo que um usuário não autenticado para carregar arquivos.
- Passagem de diretório FTP - permitindo que os usuários deixem o diretório FTP e naveguem na estrutura de diretório do sistema operacional.

5 O QUE É METASPLOIT

5.1 Metasploit

O Metasploit é uma estrutura de teste de segurança e penetração de computadores multiuso. Intencionalmente modular, permite ao invasor misturar e combinar scanners, explorações e cargas úteis em um único ataque.

Originalmente criado por HD Moore para análise de segurança, foi posteriormente adquirido pelo Rapid7, que adicionou versões comerciais mais intuitivas e baseadas em GUI. Metasploit é considerado a estrutura de desenvolvimento de exploração de fato. É usado em todo o mundo para análises de segurança legítimas e atividades não autorizadas.

Atualmente, o Metasploit está disponível em duas edições:

- Metasploit Framework - a versão gratuita da linha de comando de código aberto (instalada por padrão no Kali Linux).

- Metasploit Pro - uma versão gráfica completa que inclui assistentes de início rápido, fácil verificação e validação de vulnerabilidades, *phishing* campanhas e relatórios.

Além dos projetos Rapid7, existem dois *spin-offs* populares baseados em GUI:

- Armitage - uma GUI para Metasploit criada por Raphael Mudge.
- Cobalt Strike - uma versão comercial do Armitage com recursos avançados e relatórios. Os recursos do Metasploit são organizados em módulos. Existem seis tipos básicos:
- Explorações - software de ataque que fornece uma carga útil.
- Cargas úteis - código que é executado remotamente.
- Postagem - tarefas adicionais que você pode executar em um host comprometido.
- Auxiliar - scanners, sniffers, fuzzers, spoofers e outros que não exploram recursos.
- Codificadores - asseguram que as cargas úteis cheguem ao destino intactas e não detectadas.
- Nops - mantêm os tamanhos de carga útil consistentes nas tentativas de exploração.

Cada tipo possui muitos módulos internos, agrupados por subtipo ou plataforma. Ao usar o Metasploit, você especifica um módulo específico por seu caminho. Por exemplo:

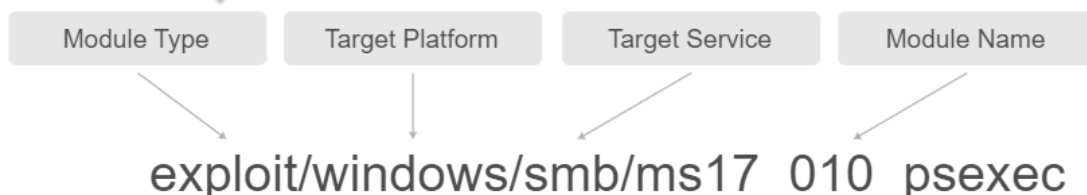


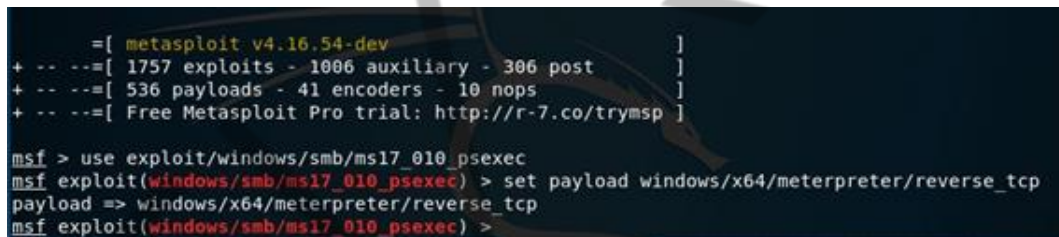
Figura 14 - Metasploit
Fonte: Elaborado pelo autor (2019)

Você inicia o Metasploit Framework selecionando o iniciador do MSF na barra de ferramentas da área de trabalho Kali ou inserindo `msfconsole` em uma janela

normal do terminal. Depois de especificar o módulo, você geralmente precisa definir opções. Alguns são obrigatórios e outros são opcionais. Os exemplos incluem:

- RHOSTS - nomes ou endereços (remotos) de destino.
- LHOST - de atacante ("ouvinte").
- RPORT - porta de destino.
- LPORT - porta de ouvinte de atacante.
- SMBUser - um nome de usuário para ataques baseados em SMB.
- SMBPass - uma senha para ataques baseados em SMB.

Se você estiver usando uma exploração, também precisará especificar a carga útil. A carga útil é um programa que é executado no destino uma vez comprometido. A carga útil mais popular é o Meterpreter, que é uma lista interativa baseada em menus de comandos que você pode executar no destino.



```
=[ metasploit v4.16.54-dev ]
+ -- --[ 1757 exploits - 1006 auxiliary - 306 post ]
+ -- --[ 536 payloads - 41 encoders - 10 nops ]
+ -- --[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

msf > use exploit/windows/smb/ms17_010_psexec
msf exploit(windows/smb/ms17_010_psexec) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) >
```

Figura 15 - Console
Fonte: Elaborado pelo autor (2019)

O Metasploit Framework e o Metasploit Pro permitem procurar e selecionar módulos de verificação. Armitage e Metasploit Pro têm uma interface GUI conveniente que muitos acham mais fácil de usar.

Você pode pesquisar por vários critérios, incluindo uma sequência simples (a sequência pode aparecer em qualquer lugar do nome/data/classificação/descrição), número de cve, plataforma afetada, aplicativo (cliente ou servidor) e tipo (exploração, auxiliar, carga útil etc). Você também pode especificar -o <nome do arquivo> para salvar a saída no formato CSV. Não diferencia maiúsculas de minúsculas.

Exemplos de pesquisa:

- msf> search Tipo EternalBlue: exploit - encontre todas as explorações relacionadas ao EternalBlue.

- msf> plataforma de pesquisa: "Windows XP SP3" tipo: exploit -o /root/xpsp3_exploits.csv -
- encontre todas as explorações que se aplicam ao Windows XP SP3 e salve em xpsp3_exploits.csv.
- msf> pesquise tipo Windows / VNC: carga útil - encontre todas as cargas úteis VNC aplicáveis ao Windows.
- msf> pesquise tipo Windows / MSSQL: exploit - encontre todas as explorações que podem ser usadas no Microsoft SQL em execução no Windows.
- msf> pesquisa tipo Windows / SMB: exploit -S great - encontre todas as explorações SMB baseadas no Windows que tenham uma classificação excelente (mais confiável) (com a sequência "excelente" nos resultados da linha).
- msf> pesquisar scanner / smb - pesquise todos os scanners relacionados ao SMB.
- msf> pesquisar scanner / mssql - pesquise todos os scanners relacionados ao Microsoft SQL.

Depois de encontrar um módulo que você gostaria de experimentar, use os resultados da pesquisa para fornecer o caminho para esse módulo. Carregue o módulo e, em seguida, mostre suas opções para configurá-lo. Digite executar ou explorar para iniciá-lo.

Lembre-se de que os módulos de postagem só podem ser executados em uma sessão existente do Metasploit, depois que você já tiver explorado o destino. O exemplo a seguir procura por scanners MSSQL, depois configura e executa mssql_ping. Esse módulo verifica um host/intervalo em busca de qualquer máquina que esteja escutando no UDP 1434 (provavelmente aberto para qualquer servidor MSSQL) e tenta determinar a porta TCP (padrão ou não) que o Microsoft SQL Server está usando.

Aqui está um exemplo de pesquisa para scanners MSSQL.

```
msf > search scanner/mssql

Matching Modules
=====

  Name                                     Disclosure Date  Rank   Description
  ----                                     -
  auxiliary/scanner/mssql/mssql_hashdump  normal          MSSQL Password Hashdump
  auxiliary/scanner/mssql/mssql_login     normal          MSSQL Login Utility
  auxiliary/scanner/mssql/mssql_ping      normal          MSSQL Ping Utility
  auxiliary/scanner/mssql/mssql_schemadump normal          MSSQL Schema Dump

msf > use auxiliary/scanner/mssql/mssql_ping
msf auxiliary(scanner/mssql/mssql_ping) > show options

Module options (auxiliary/scanner/mssql/mssql_ping):

  Name             Current Setting  Required  Description
  ----             -
  PASSWORD          no              The password for the specified username
  RHOSTS            yes             The target address range or CIDR identifier
  TDSENCRYPTION     false           Use TLS/SSL for TDS data "Force Encryption"
  THREADS           1              The number of concurrent threads
  USERNAME          sa              The username to authenticate as
  USE_WINDOWS_AUTH  false          Use windows authentication (requires DOMAIN option set)

msf auxiliary(scanner/mssql/mssql_ping) > set RHOSTS 192.168.74.10-50
RHOSTS => 192.168.74.10-50
msf auxiliary(scanner/mssql/mssql_ping) > run
```

Figura 16 – Search
Fonte: Elaborado pelo autor (2019)

Você pode ter várias sessões do MSF/Meterpreter em execução simultaneamente. Aqui estão alguns exemplos de sintaxe para gerenciá-los:

Pressione Ctrl + Z para colocar sua sessão atual em segundo plano.

msf> sessions -l - lista todas as sessões atualmente em execução
msf> sessions 2 - alterne para a sessão nº 2 Gerenciando sessões do Meterpreter. Aqui está um exemplo de gerenciamento de várias sessões do Meterpreter.

```
msf > sessions -l

Active sessions
=====

  Id  Name  Type      Information                                     Connection
  --  ---  -
  1    shell php/php  192.168.74.134:46749 -> 192.168.74.20:3312 (192.168.74.20)
  2    shell cmd/unix 192.168.74.134:26942 -> 192.168.74.20:40154 (192.168.74.20)
  3    shell cmd/unix 192.168.74.134:15900 -> 192.168.74.20:43130 (192.168.74.20)

msf > sessions 2
[*] Starting interaction with 2...
```

Figura 17 – Sessions
Fonte: Elaborado pelo autor (2019)

REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014

WILHELM, T. **Professional Penetration Testing**: Creating and Learning in a Hacking Lab. 2. Waltham, MA: Syngress, 2013.